

Tiziano Becchetti

SOC Analyst | Blue Team | Detection Engineering | Incident Response

[Email](#) • [LinkedIn](#) • [GitHub](#)

PROFILO

Aspirante SOC Analyst con orientamento difensivo.

Ho costruito e gestito un home lab SOC completo e funzionante, andando oltre i noti esercizi isolati e sviluppando competenze pratiche sull'intero ciclo di detection: ingestione dei log, scrittura di regole custom (Wazuh, Suricata), triage degli alert, mappatura MITRE ATT&CK con risposta agli incidenti. Ho inoltre fatto pratica con Python per poter automatizzare attività di analisi e parsing dei log.

Lavoro con un approccio critico orientato al dato, facendo tesoro dell'esperienze nate dal laboratorio.

HIGHLIGHT

- ▶ **Kill chain completa rilevata e ricostruita:** simulata kill chain end-to-end (poisoning LLMNR → cracking offline → accesso al DC via WinRM → DCSync su NTDS.DIT → Pass-the-Hash con l'hash NT verso una workstation con privilegi SYSTEM), fase di lateral movement rilevata in meno di 5 secondi dall'alert automatico (Wazuh rule 92650, L12).
- ▶ **Detection engineering custom:** scritte regole proprietarie Wazuh (100001, LLMNR/NBT-NS, MITRE T1557.001) e Suricata (SID 9000001/9000002), oltre alla gestione di 71.411 regole su Security Onion (~53.7k abilitate). Copertura mappata su una heatmap MITRE ATT&CK (7 scenari, 12 tecniche, con i gap di detection evidenziati).
- ▶ **Triage CVE orientato al rischio reale:** 1.561 vulnerabilità da scan GVM, 23 Critical verificate manualmente contro lo stato effettivo dei servizi, fino a 1 sola esposizione realmente sfruttabile, separando la criticità reale dal rumore.
- ▶ **Hardening misurato:** Security Baseline applicata via GPO con incremento dello score SCA dal 24% al 40%, documentando ogni controllo e logica delle scelte.
- ▶ **Correlazione multi-tool e onestà sui gap:** alert Wazuh integrati in Security Onion via syslog e validazione incrociata con GVM, documentati esplicitamente i limiti di detection (es. credential dump via DRSUAPI non rilevato di default) con le relative azioni correttive eseguite/programmate.

COMPETENZE TECNICHE

SIEM / Monitoring	Security Onion, Wazuh (SIEM/HIDS con funzioni EDR-like, FIM/SCA), Kibana
Network IDS/IPS	Suricata, Zeek; analisi traffico, regole custom
Vulnerability Mgmt	OpenVAS / GVM, triage e prioritizzazione CVE
Detection / Threat	MITRE ATT&CK, Sigma, YARA, Sysmon, log analysis
Scripting / Automazione	Python, PowerShell, Bash
Active Directory	GPO, Security Baseline, audit policy, hardening DC
Incident Response	Triage alert, escalation L1→L2, reporting
Attacco (per detection)	Responder, Impacket, evil-winrm, hashcat

FORMAZIONE & CERTIFICAZIONI

In preparazione: CompTIA Security+

Lab & write-up completi: https://github.com/tiziano-becchetti/SOC_home_lab

IL LABORATORIO

Virtual SOC Home Lab autocostruito: dominio Active Directory monitorato da uno stack reale (Security Onion, Wazuh come SIEM/HIDS con funzioni EDR-like e FIM, Suricata e Zeek per il traffico, OpenVAS/GVM per il vulnerability management), con Kali in attacco che genera la telemetria per scrivere e validare le regole di detection.

Scenari simulati e documentati: credential harvesting (LLMNR/NBT-NS poisoning), incident response su malware, kill chain completa Pass-the-Hash, vulnerability assessment e hardening. Ogni scenario include mappatura MITRE ATT&CK, IoC e report d'incidente in stile SOC.

FORMA MENTIS

- ▶ Uso tecniche offensive per generare telemetria e migliorare la detection, anche assumendo il punto di vista di un attaccante.
- ▶ Distinguere il segnale dal rumore con triage basato sull'esposizione reale, non sul numero grezzo di alert o CVE.
- ▶ Documento anche ciò che non viene rilevato, i gap di detection sono il punto di partenza per migliorare le regole e innalzare il mio livello di consapevolezza.